



# Smart Band Communication Security

Nuno Lopes

# Motivation

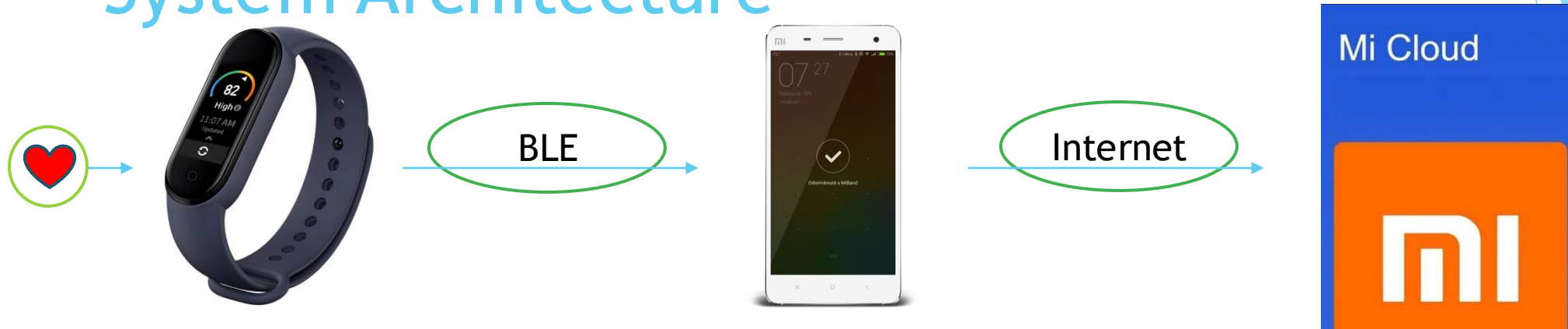
## ▶ Wearable devices:

- ▶ Wearable electronic devices with micro-controllers
  - ▶ Ex: Xiaomi Mi Smart Band family (cheap device)
- ▶ They can gather great amounts of sensible user health data.

## ▶ Questions:

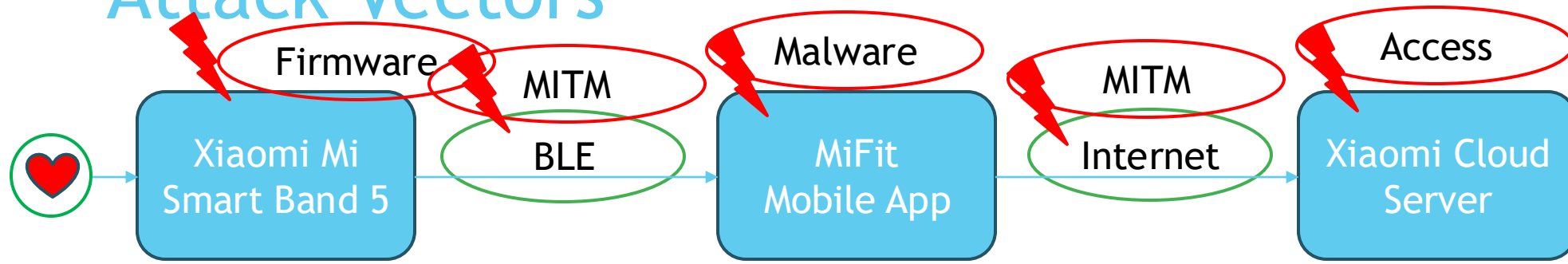
- ▶ How secure are the communications of wearable devices ?
- ▶ Where is the (personal) health data stored ?

# System Architecture



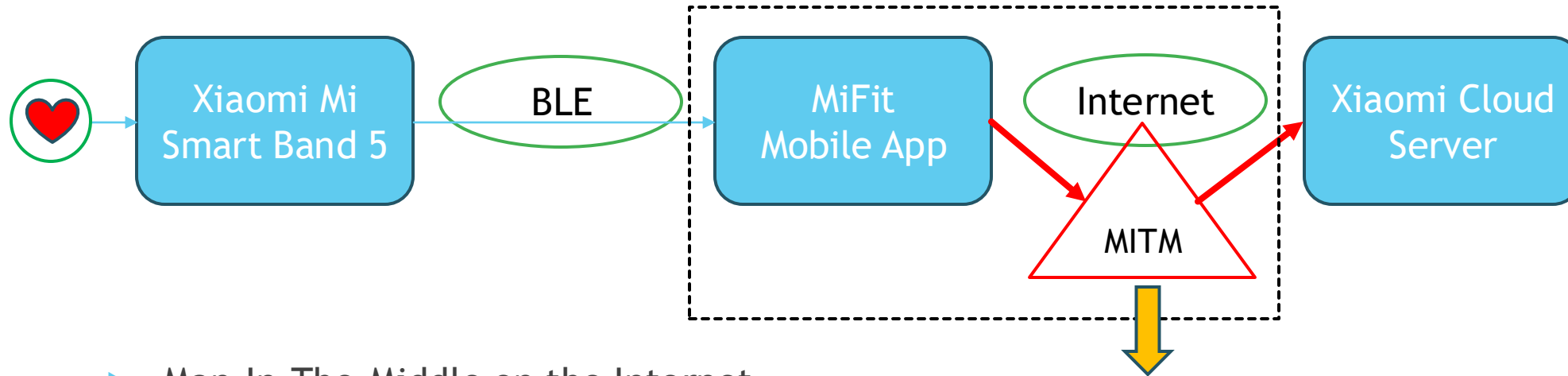
- ▶ Wearable devices capture and store user (health) data
  - ▶ Xiaomi Mi Smart Band 5
- ▶ A mobile app supported by a smartphone visualizes data and sends it to the cloud.
  - ▶ MiFit with Android
- ▶ The manufacturer's cloud stores the data for further processing.
  - ▶ Xiaomi Cloud Server

# Attack Vectors



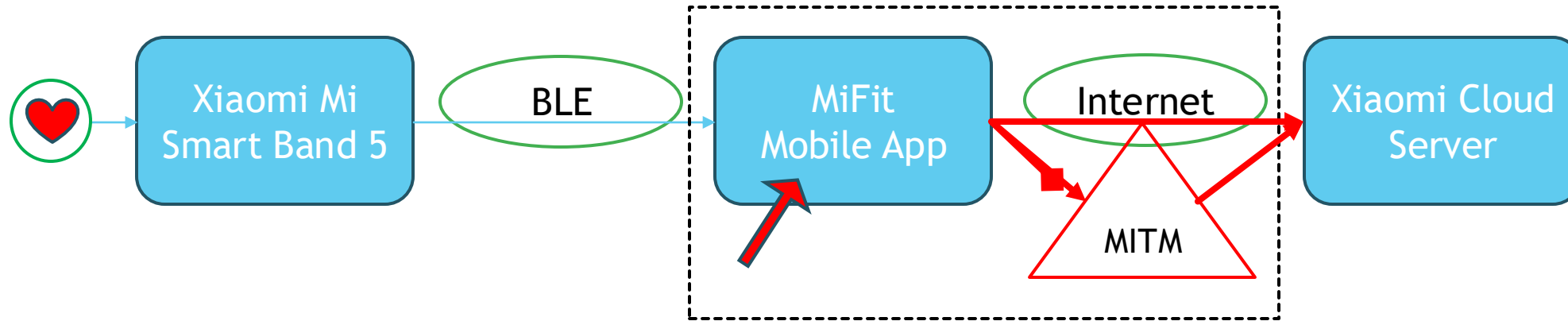
- ▶ The firmware on the device
  - ▶ Malware injection on firmware
- ▶ The Bluetooth Network (BLE) between Device & Smartphone
  - ▶ Man-in-the-middle on Bluetooth
- ▶ The MiFit app
  - ▶ Malware injection on Android Application Pack
- ▶ The Internet between Smartphone & Cloud Server
  - ▶ Man-in-the-middle on Internet
- ▶ The Xiaomi Cloud
  - ▶ Gathering access to the Xiaomi Server

# A MITM Internet Attack Description



- ▶ Man-In-The-Middle on the Internet,
  - ▶ in-between the MiFit app and Cloud Server app
- ▶ Installing a MITM proxy to capture packets, **pcap-remote**,
  - ▶ runs on the smartphone itself
  - ▶ <https://github.com/egorovandreyrm/pcap-remote>
- ▶ Visualize packets on Wireshark, using the *pcapng* format.

# Certificate Pinning



- ▶ Secure communication on the Internet through certificates
  - ▶ Hard-coding known certificate used by the manufacturer server on the application.
  - ▶ No possibility to change the pinned certificate.
- ▶ Challenge: circumventing Certificate Pinning
  - ▶ Changing hard-coded certificates in the Android app
  - ▶ unpack the MiFit APK (Android Application Pack)
  - ▶ inject new (self-signed ?) certificate for the pcap-remote

# Captured Packet Visualization

- ▶ Packets were transmitted in clear text.
- ▶ Data such as passwords were readable.
- ▶ To help mitigate MITM attacks, certificate pinning techniques should be added to the smartphone application in parallel with a mutual SSL authentication.

Wireshark · Packet 60 · MI-FIT.pcapng

▼ Hypertext Transfer Protocol

▼ POST /registrations/afonso.almeida330%40gmail.com/tokens HTTP/1.1\r\n

- > [Expert Info (Chat/Sequence): POST /registrations/afonso.almeida330%40gmail.com/tokens HTTP/1.1\r\n]
- Request Method: POST
- Request URI: /registrations/afonso.almeida330%40gmail.com/tokens
- Request Version: HTTP/1.1
- app\_name: com.xiaomi.hm.health\r\n
- Accept-Language: pt-PT\r\n
- X-Request-Id: 4c0c1798-f6f7-45d7-acbf-16f02945ce3c\r\n
- Content-Type: application/x-www-form-urlencoded; charset=UTF-8\r\n
- User-Agent: Dalvik/2.1.0 (Linux; U; Android 11; T770H Build/RKQ1.210107.001)\r\n
- Host: api-user.huami.com\r\n
- Connection: Keep-Alive\r\n
- Accept-Encoding: gzip\r\n
- > Content-Length: 206\r\n
- \r\n
- [Full request URI: <https://api-user.huami.com/registrations/afonso.almeida330%40gmail.com/tokens>]
- [HTTP request 1/1]
- [Response in frame: 62]
- File Data: 206 bytes

▼ HTML Form URL Encoded: application/x-www-form-urlencoded

- > Form item: "state" = "REDIRECTION"
- > Form item: "client\_id" = "HuaMi"
- > Form item: "password" = [REDACTED]
- > Form item: "redirect\_uri" = "https://s3-us-west-2.amazonaws.com/hm-registration/successsignin.html"
- > Form item: "region" = "us-west-2"
- > Form item: "token" = "access"
- > Form item: "token" = "refresh"
- > Form item: "country\_code" = "PT"

0020 50 18 00 a1 ed ed 00 00 17 03 03 02 83 00 00 00 P.....

0030 00 00 00 00 01 b0 81 08 ae a7 be 78 ee 3b 58 f7 .....X;

Frame (688 bytes)    Decrypted TLS (619 bytes)

# Acknowledgements

- ▶ The material in this presentation was based on the work of Afonso Almeida within the research projects at IPCA:
  - ▶ "Cybers SeC IP"
  - ▶ "Sleeping at Wheels"
- ▶ Paper:
  - ▶ A Almeida, N Mateus-Coelho, N Lopes, I Portela, *Paranoid OS: Wearable Trackers*, 2022.
  - ▶ <https://doi.org/10.1016/j.procs.2022.08.104>